Terms of Reference for FOI Database - Legal Unit, HYPREP

Project: Freedom of Information (FOI) Management System

Version: 1.0

Date: 2026-04-30

Contract Duration: 6 Months

1 Objectives

This Terms of Reference describes the requirements for the design, development, testing, deployment, and maintenance of a web-based FOI (Freedom of Information) Request Management System intended for HYPREP (Hydrocarbon Pollution Remediation Project). The system will manage FOI requests and responses, categorize cases (filed, pending, concluded), schedule court dates, and provide role-based dashboards and reporting for Legal Unit staff and system administrators.

2 Scope

The system will support the entire lifecycle of FOI requests and FOI-related legal cases, including:

- Submission and upload of FOI requests and responses
- Case creation, categorization, prioritization, assignment, and tracking
- Scheduling and tracking court dates
- Role-based dashboards (Admin, Super-Admin, Legal Unit staff, General Users)
- Comprehensive reporting (weekly, monthly, quarterly, yearly)
- Document management with secure uploads and versioning
- Notifications via email and in-app messaging
- Audit logging and compliance features

The system will be a responsive web application accessible via modern desktop and mobile browsers.

3. Product Perspective

The FOI Management System is a standalone web application that can integrate with HYPREP's existing authentication (SSO/LDAP), email systems, and potential case-management or document management backends. It will serve as the authoritative record of FOI requests and related legal cases for HYPREP.

4. System Interfaces

- Authentication service (SSO/LDAP/OAuth2)
- SMTP/Email Provider (SendGrid, SES, or internal SMTP)
- Document Storage (cloud: S3, Azure Blob; or on-premise file server)
- Optional: SMS gateway
- Optional: Court scheduling external systems (if integrated)
- RESTful API for third-party integration

5 User Classes and Characteristics

a. Super-Admin

- Full system control: create/delete organizations, manage users and roles, change system settings, view all case data, run emergency exports, manage data retention.
- Typically an IT or governance officer.

b. Admin

- Manage users, assign cases, manage categories/tags, review reports, moderate content, set permissions.

c. **Legal Unit Staff (Lawyers/Paralegals/Case Officers)**

    - Create/Update case records, upload FOI responses, add hearing/court dates, annotate case documents, mark case statuses, access Legal Unit dashboard and queue.

d. **Clerk / Support Staff**

    - Administer documents, manage scheduling, perform data entry, assist Legal Unit staff.

e. **General User / Requestor**

    - Submit FOI requests, view their own requests and responses, receive notifications, create appeals.

f. **Auditor / Read-only Inspector**

    - Read-only access for compliance/audit purposes.

g. **External Stakeholders** (optional)

    - External lawyers, government officials; access is limited to assigned cases only.

2.4 Operating Environment

- Web browsers: Latest Chrome, Firefox, Edge, Safari (desktop and mobile)
- Server: Linux (Ubuntu 20.04+), Docker containers
- Database: PostgreSQL (preferred) or MySQL
- Storage: S3-compatible object storage or equivalent
- Authorization: Role-based access control (RBAC) with optional attribute-based extensions

6. Design and Implementation Constraints

- Comply with security best practices (OWASP)
- Sensitive documents must be stored encrypted at rest
- Data retention and deletion must meet HYPREP policy
- Nigerian FOI legal timelines and privacy obligations must be respected
- System should support migrating existing records via CSV or API

7. Assumptions and Dependencies

- HYPREP will provide organizational policies and any specific classification taxonomy.
- Integration endpoints (SSO, SMTP) will be made available before deployment.
- Users will have internet access and modern browsers.

---

8. Functional Requirements

Each requirement is prefixed with an ID `FR-###` for traceability.

User & Access Management

- **FR-001: User Registration** — Support admin-created accounts and self-registration (with email verification). Super-admin may disable self-registration.
- **FR-002: Authentication** — Support username/password, SSO (SAML/OAuth2), and MFA (TOTP or SMS). Sessions must expire after configurable inactivity.
- **FR-003: Roles & Permissions** — RBAC implementation with default roles (Super-Admin, Admin, Legal, Clerk, Requestor, Auditor). Admins manage role

assignments (FR-003a: Custom Roles).

- **FR-004: User Profile** — Each user has profile data: name, contact, organization, position, phone, photo, security settings.

- **FR-005: Password Policies** — Enforce complexity, rotation rules, and account lockout after configurable failed attempts.

- **FR-006: Audit & Logs** — All user login attempts and privileged actions are logged (see Audit Trail section).

9. FOI Request Lifecycle

- **FR-010: Submit FOI Request** — Public/registered users can submit FOI requests via form or file upload (PDF, DOCX) and select confidentiality level.
    - Fields: Requestor name, contact, organization, subject, description, attachments, preferred response format, date submitted.

- **FR-011: Automatic Case Creation** — Each FOI request creates a case record with unique case ID and initial status `Filed`.

- **FR-012: Acknowledgement** — System sends automated acknowledgement (email & in-app) with case ID and expected statutory response date.

- **FR-013: Assign Case** — Admins or routing rules can assign cases to Legal Unit staff or teams.

- **FR-014: Response Upload** — Authorized staff can upload FOI responses, link them to the request, and publish them to the requestor if allowed.

- **FR-015: Response Versioning** — Document version control for responses—previous versions must remain accessible to authorized roles.

- **FR-016: Status Updates** — Status values: Filed, In Review, Pending (info required), Responded, Escalated, Appeal, Closed, Rejected. Status changes trigger notifications.

- **FR-017: SLA & Timer** — Track statutory deadlines; flag approaching and overdue requests; configurable escalation policies.

10. Case Management

- **FR-020: Case Dashboard** — Show lists: All Cases, Filed, Pending, Responded, Concluded/Closed, Escalated. Provide counts, filters and quick actions.

- **FR-021: Case Details Page** — Display full timeline: requests, responses, attachments, notes, assignments, court dates, activities.

- **FR-022: Internal Notes & Collaboration** — Legal staff can add internal (private) notes, tag colleagues, and create tasks.

- **FR-023: Tagging & Categorization** — Tag cases with categories, priority, departments, and custom metadata fields.

- **FR-024: Case Linking** — Link related cases (e.g., same requestor or same subject matter).

- **FR-025: Case Closure** — Authorized users can close cases and record closure reason and outcome codes.

3.4 Legal Unit Workflows

- **FR-030: Legal Dashboard** — Dedicated Legal Unit view: assigned cases, court calendar, tasks, high priority items, and legal metrics.

- **FR-031: Case Review Queue** — Legal staff can triage cases: accept, reassign, escalate, request further info.

- **FR-032: Document Redaction** — Allow authorized staff to redact parts of a document (implemented via redaction tool or marked notes) before publishing.

- **FR-033: Templates & Letter Generation** — Create templated responses, notices, and affidavits with merge fields from case data.

11. Court Date Scheduling & Calendar

- **Schedule Court Dates** — Add hearings/court dates to a case, with court location, judge/court details, and note attachments.

- **Calendar View** — Monthly/weekly/daily calendar for Legal Unit and Admins; filterable by user, team, court, or case.

- **Notifications for Hearings** — Email/in-app reminders for upcoming court dates (configurable lead times).

- **Court Outcome Recording** — Record outcome of hearings and link to case updates and documents.

12. Document Management & File Uploads

- **Uploads** — Support PDF, DOC, DOCX, XLSX, PNG, JPEG, and others. Max file size configurable. Virus scanning on upload.

- **Storage** — Store documents in encrypted object storage with metadata, version history, and access controls.

- **Preview & Download** — In-browser preview of common document types; downloads are permission-checked.

- **Retention Policies** — Apply retention labels and delete/archive documents per policy.

- **OCR & Searchable PDFs** — Optional OCR pipeline for scanned documents to support full-text search

13. Notifications & Alerts

- **Channels** — Email and in-app notifications. Optional SMS.

- **Event-driven** — Notify on: case assignment, status change, uploaded response, due date approaching, court date, admin alerts.

- **Notification Preferences** — Users can configure what notifications they receive and preferred channels.

14. Reporting & Analytics

- **Standard Reports** — Weekly, Monthly, Quarterly, Yearly FOI request reports that include:
    - Number of requests received
    - By status (filed/pending/responded/concluded)
    - Average response time
    - SLA compliance rate
    - Top requesters
    - Requests by department/subject
    - Appeals and escalations
- **Custom Report Builder** — Build ad-hoc reports with date ranges, filters, groupings, and export to CSV/PDF.
- **Dashboards & Visuals** — Visual charts for trends, SLA heatmaps, case aging, and workload distribution.
- **Scheduled Report Delivery** — Allow scheduled emails of periodic reports to stakeholders.

15. Search, Filter & Advanced Query

- **Global Search** — Search across case ID, requestor name, subject, content (if OCR enabled), tags, and document text.
- **Advanced Filters** — Filter by date ranges, status, assignee, department, priority, court dates, and custom metadata.
- **Saved Filters & Views** — Users can save filter views and share with team.

16. Audit Trail & Logging

- **Activity Log** — Record create/update/delete actions for cases, documents, users, and system settings (immutable storage or append-only log).
- **Access Logs** — Detailed logs of document access and downloads.
- **Exportable Audit** — Export logs for compliance review in CSV/JSON.

17. Admin & Super-Admin Controls

- **System Settings** — Configure email server, MFA, file storage, retention, maximum upload sizes.
- **Organization Settings** — Manage departments, court lists, legal teams, classification taxonomies.
- **Data Export & Backup** — Full dataset export, scheduled backups, and restore functionality.
- **System Monitoring** — Health checks, service status, and performance metrics view.

18. Bulk Operations & Import/Export

- **Bulk Upload** — Bulk import cases/requests via CSV with mapping UI.
- **Bulk Actions** — Bulk assign, bulk close, bulk export for selected cases.
- **API Endpoints** — Provide REST API for case creation, retrieval, updates, and report pulls with OAuth2 security.

19. API & Integration

- **REST API** — CRUD operations for cases, documents, users; report endpoints; authentication via OAuth2/JWT.
- **Webhooks** — Support webhooks for event-driven integration (case created, updated, response published).

- **SSO Integration** — SAML or OAuth2 based SSO for central authentication

20. Security

- **Data Encryption** — Encrypt data at rest (AES-256) and in transit (TLS 1.2+).
- **RBAC & Least Privilege** — Enforce role-based permissions; sensitive actions require elevated privileges.
- **Input Validation & Sanitization** — Protect against XSS, SQL injection, CSRF.
- **Vulnerability Management** — Regular vulnerability scanning and patching.
- **MFA** — Support multi-factor authentication for privileged accounts.
- **Secure File Handling** — Virus scanning, file type validation, and sandboxing previews.

21. Performance

- **Response Time** — 95th percentile page load for common pages < 2s under normal load.
- **API Latency** — API requests under 300ms for common endpoints under normal load.
- **Concurrency** — Support at least 1,000 concurrent users in initial deployment with horizontal scaling options.

22. Scalability

- System should be horizontally scalable for web servers and worker processes; database scale-up options and read replicas supported.

23. Availability & Recovery

- **Uptime** — Target 99.9% availability (excluding scheduled maintenance).

- **Backup & Restore** — Daily backups, with tested restore procedures and point-in-time recovery for DB.

- **Disaster Recovery** — Documented DR plan, RTO and RPO targets (to be defined with HYPREP).

24. Usability & Accessibility

- **Responsive UI** — Usable on desktop and mobile devices.

- **Accessibility** — WCAG 2.1 AA compliance.

- **Onboarding & Help** — Guided onboarding, tooltips, in-app help, and downloadable user guides.

25. Localization & Internationalization

- Support English (primary). Dates shown in local Nigerian timezone (Africa/Lagos). Enable future support for other languages.

26. Maintainability & Supportability

- Codebase should be modular with automated tests. CI/CD pipelines, containerized deployment, and comprehensive logging/metrics.

27. Data Model / Entities (High-level)

Core entities and key attributes (simplified):

1. **User**: id, name, email, role_id, phone, organization, position, status, created_at, updated_at

2. **Role**: id, name, permissions

3. **Case (FOI Request)**: id, case_number, requestor_id, subject, description, assigned_to, status, priority, tags, department, date_submitted,

statutory_due_date, date_closed

4. **Document**: id, case_id, file_name, file_type, file_size, url, uploaded_by, is_public, version, checksum, created_at

5. **Note / Activity**: id, case_id, user_id, type (internal/public), content, attachments, created_at

6. **CourtDate**: id, case_id, date, time, court_name, location, notes, outcome, created_by

7. **AuditLog**: id, entity_type, entity_id, action, performed_by, timestamp, details

8. **Report**: saved_report_id, name, creator_id, filters, schedule, last_run

ER diagrams and normalized schema to be produced during design phase.

28. External Interfaces

- **Authentication**: SSO (SAML/OAuth2) and local DB auth
- **Email**: SMTP or SendGrid API
- **Storage**: S3-compatible or Azure Blob
- **SMS provider**: Twilio or local SMS gateway (optional)
- **OCR service**: Optional (Tesseract or cloud OCR)
- **Anti-virus scanning**: ClamAV or cloud equivalent

29. System Architecture (High-level)

Suggested architecture:

- **Frontend**: React (TypeScript) with server-side rendering optional or Next.js; responsive design.

- **Backend**: Node.js/Express or Python/Django or Java/Spring Boot (RESTful API).
- **Database**: PostgreSQL primary; Redis for caching and background job queue.
- **Object Storage**: S3-compatible for documents
- **Background Workers**: Celery/Sidekiq/Node worker for email, OCR, virus scan, report generation
- **CI/CD**: GitHub Actions/GitLab CI; Docker containers; Kubernetes optional
- **Monitoring**: Prometheus/Grafana, Sentry for errors

Security and network layers: VPC, firewall, WAF, TLS termination, private subnets for DB.

30. Wireframes & UI/UX Guidelines

Provide wireframes for at least:

- Login / SSO page
- Super-admin dashboard
- Admin user management page
- Legal Unit dashboard
- Case list (All / Filed / Pending / Concluded)
- Case detail page with timeline and document viewer
- Court calendar view
- Report builder and predefined reports page
- Global search results page

UI guidelines:

- Clean, simple layout; left navigation, top utility bar
- Prominent quick-create button for FOI Request by staff
- Card components for case summaries with color-coded status
- Filters and saved-views in list pages
- Bulk-select checkboxes and bulk actions menu

31. Acceptance Criteria & Test Cases (High Level)

Acceptance criteria (examples):

- Authorized users can create, update and close cases; unauthorized cannot.
- File uploads succeed and are viewable/downloadable by permitted roles.
- Notifications are sent for case assignment and due date reminders.
- Reports for weekly/monthly/quarterly/yearly are accurate and exportable.
- Audit logs capture create/update/delete operations.

High-level test cases:

- Unit tests for business logic
- Integration tests for API endpoints
- End-to-end tests for critical user flows (case creation, response publishing, report generation)
- Security tests (penetration tests and vulnerability scans)

32. Deployment, Operations & Maintenance

- **Deployment**: Containerized images deployed via CI/CD; staging and production environments.

- **Monitoring**: Application metrics, error tracking and uptime checks.

- **Support**: SLA for bug fixes and critical incidents; maintenance windows communicated in advance.

- **Backups**: Daily DB backups and file storage backups; retention policy managed by Admin.